

RELATÓRIO DE ANÁLISE DE VULNERABILIDADES

Sistema de Gestão de Oficina Mecânica — SOAT Fase 1

Data: 01/05/2026 | Ferramenta: Trivy v0.70 | Formato: Filesystem Scan

1. Resumo Executivo

O presente relatório descreve os resultados da análise de segurança realizada no projeto de back-end do sistema de gestão de oficina mecânica, desenvolvido como Tech Challenge da Fase 1 do programa SOAT. A análise foi conduzida utilizando a ferramenta Trivy, que realiza varredura de vulnerabilidades conhecidas (CVEs) nas dependências declaradas no arquivo pom.xml.

Foram identificadas 4 vulnerabilidades no total, distribuídas entre os componentes Apache Tomcat Embed e Jackson Core. Nenhuma vulnerabilidade de severidade CRITICAL foi encontrada. As vulnerabilidades HIGH identificadas possuem correções disponíveis e foram endereçadas durante o processo de análise.

Severidade	Quantidade	Status
CRITICAL	0	Nenhuma encontrada
HIGH	3	2 corrigidas, 1 pendente
MEDIUM	1	Pendente de fix upstream
LOW	0	Nenhuma encontrada
TOTAL	4	

2. Ambiente e Metodologia

A varredura foi executada utilizando a ferramenta Trivy em modo de escaneamento de sistema de arquivos (filesystem scan), analisando o arquivo pom.xml do projeto Maven. A ferramenta consulta bases de dados de vulnerabilidades conhecidas, incluindo o NVD (National Vulnerability Database) e advisories do GitHub.

Parâmetro	Valor
Ferramenta	Trivy v0.70
Modo de scan	Filesystem (fs)
Alvo	pom.xml
Base de dados	trivy-db:2 (mirror.gcr.io/aquasec)
Framework	Spring Boot 4.0.5
Linguagem	Java 21
Data da análise	01/05/2026

3. Vulnerabilidades Encontradas

As vulnerabilidades identificadas estão concentradas em dois componentes: o servidor Apache Tomcat Embed (utilizado internamente pelo Spring Boot) e a biblioteca Jackson Core (utilizada para processamento JSON). A seguir, cada vulnerabilidade é descrita individualmente.

3.1 CVE-2026-34483 — Apache Tomcat (HIGH)

Campo	Detalhe
CVE	CVE-2026-34483
Severidade	HIGH
Componente	org.apache.tomcat.embed:tomcat-embed-core
Versao afetada	11.0.20
Versao corrigida	9.0.116, 10.1.54, 11.0.21
Status	CORRIGIDA — versao 11.0.21 aplicada no pom.xml

Descricao: Vulnerabilidade de divulgacao de informacoes no componente JsonAccessLogValve do Apache Tomcat. O encoding incorreto de dados de requisicao pode expor informacoes sensiveis nos logs de acesso quando configurado com o formato JSON. Apesar de ser classificada como HIGH, o impacto e limitado a ambientes que utilizam explicitamente o JsonAccessLogValve, o que nao e o caso desta aplicacao.

Acao tomada: A versao do tomcat-embed-core foi atualizada para 11.0.21 diretamente no pom.xml, sobrescrevendo a versao gerenciada pelo Spring Boot.

3.2 CVE-2026-34487 — Apache Tomcat (HIGH)

Campo	Detalhe
CVE	CVE-2026-34487
Severidade	HIGH
Componente	org.apache.tomcat.embed:tomcat-embed-core
Versao afetada	11.0.20
Versao corrigida	9.0.117, 10.1.54, 11.0.21
Status	CORRIGIDA — versao 11.0.21 aplicada no pom.xml

Descricao: Vulnerabilidade de divulgacao de dados sensiveis em arquivos de log do Apache Tomcat. Determinadas configuracoes de logging podem resultar no registro inadvertido de informacoes confidenciais, como tokens de autenticao ou dados pessoais, nos arquivos de log do servidor.

Acao tomada: Corrigida pela atualizacao para versao 11.0.21 do tomcat-embed-core. Adicionalmente, recomenda-se revisar as configuracoes de logging em producao para garantir que dados sensiveis nao sejam registrados.

3.3 CVE-2026-34500 — Apache Tomcat (MEDIUM)

Campo	Detalhe
CVE	CVE-2026-34500

Severidade	MEDIUM
Componente	org.apache.tomcat.embed:tomcat-embed-core
Versao afetada	11.0.20
Versao corrigida	Nao disponivel ainda
Status	PENDENTE — aguardando correcao do fabricante

Descricao: Vulnerabilidade de bypass de autenticao via configuracao incorreta de certificado cliente no Apache Tomcat. A vulnerabilidade pode permitir que um atacante contorne mecanismos de autenticao baseados em certificado TLS/SSL em configuracoes especificas de mutual TLS (mTLS). Esta aplicacao nao utiliza autenticao por certificado cliente, reduzindo significativamente o risco.

Acao tomada: Sem correcao disponivel no momento. Monitoramento ativo aguardando lancamento de versao corrigida pelo projeto Apache Tomcat. O risco e considerado baixo para esta aplicacao pois nao utiliza autenticao por certificado cliente.

3.4 GHSA-2m67-wjppj-xhg9 — Jackson Core (HIGH)

Campo	Detalhe
Advisory	GHSA-2m67-wjppj-xhg9
Severidade	HIGH
Componente	tools.jackson.core:jackson-core
Versao afetada	3.1.0
Versao corrigida	3.1.1
Status	PENDENTE — depende de atualizacao do Spring Boot 4.x

Descricao: Vulnerabilidade de bypass de restricao de tamanho de documento nos parsers bloqueantes, assincronos e DataInput do Jackson Core. Um atacante poderia enviar payloads JSON excessivamente grandes, potencialmente causando condicoes de negacao de servico (DoS) por esgotamento de memoria ou CPU. O risco e mitigado parcialmente pelo uso de JWT e autenticao obrigatoria em todos os endpoints.

Acao tomada: A versao 3.1.0 e gerenciada pelo Spring Boot 4.0.5. A correcao depende de uma atualizacao do Spring Boot que inclua Jackson Core 3.1.1. Recomenda-se monitorar o lancamento de Spring Boot 4.0.6 ou superior. Como mitigacao temporaria, considerar implementar limite de tamanho de requisicao via configuracao do servidor.

4. Analise do pom.xml

Alem das vulnerabilidades identificadas pelo Trivy, foi realizada uma revisao manual do arquivo pom.xml do projeto. Os seguintes pontos foram observados:

Spring Boot 4.0.5: Versao recente e estavel. Nenhuma vulnerabilidade critica identificada no framework principal.

Lombok 1.18.44: Versao atual. Sem vulnerabilidades conhecidas.

PostgreSQL Driver 42.7.10: Versao segura e atualizada.

springdoc-openapi 2.8.6: Versao compativel com Spring Boot 4.x. Sem vulnerabilidades conhecidas.

jjwt 0.12.5: Versao atual da biblioteca JWT. Sem vulnerabilidades conhecidas.

JaCoCo 0.8.11: Plugin de cobertura de testes. Sem impacto em segurança de produção.

tomcat-embed-core 11.0.21: Versão atualizada manualmente para corrigir CVE-2026-34483 e CVE-2026-34487.

5. Recomendacoes

Curto prazo:

- Monitorar o lançamento do Spring Boot 4.0.6+ que deve incluir Jackson Core 3.1.1.
- Implementar limite de tamanho de requisição HTTP para mitigar o risco do GHSA-2m67-wjpj-xhg9.
- Revisar configurações de logging para garantir que dados sensíveis não sejam registrados.

Medio prazo:

- Implementar validação completa de CPF com algoritmo de dígitos verificadores (marcado como TODO no código).
- Configurar rate limiting nos endpoints públicos para prevenir ataques de força bruta.
- Adicionar headers de segurança HTTP (HSTS, CSP, X-Frame-Options) via Spring Security.

Longo prazo:

- Executar scans de vulnerabilidade periodicamente (sugerido: a cada release).
- Considerar adicionar o OWASP Dependency Check ao pipeline de CI/CD.
- Implementar auditoria de acesso aos dados sensíveis (CPF, CNPJ).

6. Conclusao

A análise de segurança realizada no projeto identificou 4 vulnerabilidades, sendo 3 de severidade HIGH e 1 de severidade MEDIUM. Nenhuma vulnerabilidade CRITICAL foi encontrada, o que representa um perfil de segurança adequado para um MVP.

Das 4 vulnerabilidades identificadas, 2 foram imediatamente corrigidas pela atualização do componente Apache Tomcat para a versão 11.0.21. As demais dependem de atualizações de terceiros (Spring Boot e Apache Tomcat) que estão sendo monitoradas.

O projeto demonstra boas práticas de segurança com autenticação JWT implementada, validação de dados sensíveis (CPF/CNPJ e placa), controle de acesso nos endpoints administrativos e uso de variáveis de ambiente para credenciais.